Software Engineering

Lab 5

Vedant Sharma

PES2UG24CS577

Section 5-J

27-10-2026

17 - Society Dues

https://github.com/QVedant/L5-society-dues

Issue Table

No.	Issue	Type	Line(s)*	Description	Fix Approach
1	SQL Injection Vulnerability	Security – Medium	9	SQL query was constructed using an f-string, allowing potentially malicious input to alter the query.	Replaced string interpolation with a parameterized SQL query using ? placeholders.
2	Unsafe Use of eval()	Security – Medium	21	The eval() function executes arbitrary Python expressions, which can lead to code execution if the input is untrusted.	Replaced eval() with direct arithmetic using numeric arguments (amount and multiplier).
3	Hardcoded Password	Security – Low	5	A password was stored directly in the source code, exposing sensitive information and triggering Bandit warning B105.	Removed the unused hardcoded password constant from the source file.
4	Mutable Default Argument	Code Quality – Warning	8	Using history=[] as a default argument could cause the same list to be shared across multiple function calls.	Changed the default to None and initialized a new list inside the function when needed.
5	Inconsistent Function Naming	Code Quality – Convention	8	The function name addDue did not follow Python's snake_case naming convention.	Renamed the function to add_due and updated its calls in main().
6	Missing Docstrings	Code Quality – Convention	Multiple	The module and several functions lacked descriptive docstrings, reducing readability and maintainability.	Added a module docstring and docstrings for the functions.
7	Inconsistent Return Statements	Code Quality – Refactor	12–16	The collect() function did not explicitly return a value when no matching record was found.	Added return None when no matching dues record exists.
8	Incorrect None Comparison	Style – Flake8	29	The expression rows != None did not follow Python's recommended None comparison style.	Simplified pending() to return the list generated from fetchall() directly.
9	Lines Exceeding Maximum Length	Style – Flake8	4, 13, 15	Several SQL statements exceeded the configured maximum line length, reducing readability.	Split long SQL statements and function calls across multiple lines.
10	Missing Blank Lines	Style – Flake8	12	A top-level function was not separated from the preceding code by the required two blank lines.	Added the required blank lines between top-level functions.
11	Missing Final Newline	Style – Flake8 / Pylint	End of file	The Python file did not end with a newline, triggering Flake8 W292 and Pylint C0304.	Added a newline at the end of the file.

Reflection Questions

1. What is the importance of using multiple static code analysis tools instead of relying on a single tool?

Answer: Each tool focuses on a different aspect of code quality. Pylint identifies programming issues and maintainability problems, Bandit detects potential security vulnerabilities, and Flake8 checks coding style and formatting. Using all three provides a more comprehensive assessment of the program.

2. What security vulnerabilities were identified in the original society_dues.py program, and how were they fixed?

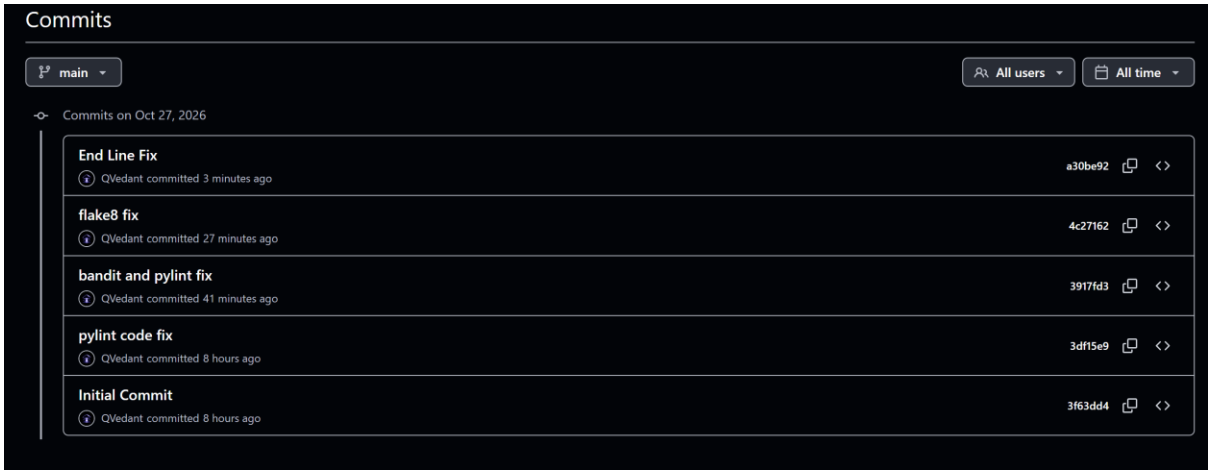
Answer: Bandit identified a hardcoded password, a potential SQL injection vulnerability caused by constructing queries with f-strings, and the unsafe use of eval(). These issues were addressed by removing the unused password, using parameterized SQL queries, and replacing eval() with direct arithmetic using numeric arguments.

3. How does fixing code quality and style issues improve the maintainability of a Python program?

Answer: Following naming conventions, adding docstrings, avoiding mutable default arguments, and formatting code consistently make a program easier to understand, debug, and modify. In this lab, these improvements helped make the functions in society_dues.py clearer and reduced potential programming errors.

4. Why is it necessary to rerun static analysis tools after fixing the reported issues?

Answer: Rerunning the tools verifies that the fixes have resolved the original findings and helps identify any remaining problems. In this lab, the initial Pylint score was 5.81/10, while the updated report showed 9.64/10. Bandit subsequently reported no issues, while Flake8 identified a missing final newline that needed correction. This demonstrates the importance of verifying changes rather than assuming the code is error-free after editing.



Prefix Reports

Pylint

prefix > pylint_report.txt

```
1  ************* Module society_dues
2  society_dues.py:13:0: C0301: Line too long (104/100) (line-too-long)
3  society_dues.py:1:0: C0114: Missing module docstring (missing-module-docstring)
4  society_dues.py:8:0: C0116: Missing function or method docstring (missing-function-docstring)
5  society_dues.py:8:0: C0103: Function name "addDue" doesn't conform to snake_case naming style (invalid-name)
6  society_dues.py:8:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
7  society_dues.py:12:0: C0116: Missing function or method docstring (missing-function-docstring)
8  society_dues.py:12:0: R1710: Either all return statements in a function should return an expression, or none of them should. (inconsistent-return-statements)
9  society_dues.py:19:0: C0116: Missing function or method docstring (missing-function-docstring)
10 society_dues.py:22:11: W0718: Catching too general exception Exception (broad-exception-caught)
11 society_dues.py:21:19: W0123: Use of eval (eval-used)
12 society_dues.py:27:0: C0116: Missing function or method docstring (missing-function-docstring)
13 society_dues.py:29:7: C0121: Comparison 'rows != None' should be 'rows is not None' (singleton-comparison)
14 society_dues.py:34:0: C0116: Missing function or method docstring (missing-function-docstring)
15
16 -----------------------------------
17 Your code has been rated at 5.81/10
18
19
```

Flake8

prefix > flake8_report.txt

```
1  society_dues.py:4:80: E501 line too long (87 > 79 characters)
2  society_dues.py:12:1: E302 expected 2 blank lines, found 0
3  society_dues.py:13:80: E501 line too long (104 > 79 characters)
4  society_dues.py:15:80: E501 line too long (92 > 79 characters)
5  society_dues.py:29:13: E711 comparison to None should be 'if cond is not None:'
6
```

Bandit



```
prefix > bandit_report.txt
1   Run started:2026-10-27 05:56:37.649188+00:00
2
3   Test results:
4   >> Issue: [B105:hardcoded_password_string] Possible hardcoded password: 'flat#101'
5      Severity: Low   Confidence: Medium
6      CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
7      More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_password_string.html
8      Location: .\society_dues.py:5:21
9   4   conn.execute("CREATE TABLE dues (flat TEXT, month TEXT, amount INTEGER, paid INTEGER)")
10  5   TREASURER_PASSWORD = "flat#101"
11  6
12
13  --------------------------------------------------
14  >> Issue: [B608:hardcoded_sql_expressions] Possible SQL injection vector through string-based query construction.
15     Severity: Medium   Confidence: Medium
16     CWE: CWE-89 (https://cwe.mitre.org/data/definitions/89.html)
17     More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b608_hardcoded_sql_expressions.html
18     Location: .\society_dues.py:9:19
19  8   def addDue(flat, month, amount, history=[]):
20  9       conn.execute(f"INSERT INTO dues VALUES ('{flat}', '{month}', {amount}, 0)")
21  10      history.append((flat, month))
22
23  --------------------------------------------------
24  >> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
25     Severity: Medium   Confidence: High
26     CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
27     More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval
28     Location: .\society_dues.py:21:19
29  20      try:
30  21          late_fee = eval(rule)
31  22      except Exception:
32
33  --------------------------------------------------
34
35  Code scanned:
36      Total lines of code: 31
37      Total lines skipped (#nosec): 0
38      Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0
39
40  Run metrics:
41      Total issues (by severity):
42          Undefined: 0
43          Low: 1
44          Medium: 2
45          High: 0
46      Total issues (by confidence):
47          Undefined: 0
48          Low: 0
49          Medium: 2
50          High: 1
51  Files skipped (0):
52
```

Postfix Reports

Bandit

postfix > bandit_after.txt

```
Run started:2026-10-27 14:11:36.146504+00:00

Test results:
    No issues identified.

Code scanned:
    Total lines of code: 48
    Total lines skipped (#nosec): 0
    Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
    Total issues (by severity):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 0
    Total issues (by confidence):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 0
Files skipped (0):
```

Flake

postfix > flake8_after.txt

Pylint

postfix > pylint_after.txt

```
Report
======
28 statements analysed.

Statistics by type
------------------

+---------+-------+-----------+-----------+------------+---------+
|type     |number |old number |difference |%documented |%badname |
+=========+=======+===========+===========+============+=========+
|module   |1      |1          |=          |100.00      |0.00     |
+---------+-------+-----------+-----------+------------+---------+
|class    |0      |NC         |NC         |0           |0        |
+---------+-------+-----------+-----------+------------+---------+
|method   |0      |NC         |NC         |0           |0        |
+---------+-------+-----------+-----------+------------+---------+
|function |5      |5          |=          |100.00      |0.00     |
+---------+-------+-----------+-----------+------------+---------+



67 lines have been analyzed
```

```
+----------+-------+------+---------+-----------+
|type      |number |%     |previous |difference |
+==========+=======+======+=========+===========+
|code      |38     |56.72 |38       |=          |
+----------+-------+------+---------+-----------+
|docstring |12     |17.91 |12       |=          |
+----------+-------+------+---------+-----------+
|comment   |0      |0.00  |NC       |NC         |
+----------+-------+------+---------+-----------+
|empty     |17     |25.37 |17       |=          |
+----------+-------+------+---------+-----------+



Duplication
-----------

+-------------------------+------+---------+-----------+
|                         |now   |previous |difference |
+=========================+======+=========+===========+
|nb duplicated lines      |0     |0        |=          |
+-------------------------+------+---------+-----------+
|percent duplicated lines |0.000 |0.000    |=          |
+-------------------------+------+---------+-----------+



Messages by category
--------------------

+-----------+-------+---------+-----------+
|type       |number |previous |difference |
+===========+=======+=========+===========+
|convention |0      |1        |-1.00      |
+-----------+-------+---------+-----------+
|refactor   |0      |0        |=          |
+-----------+-------+---------+-----------+
|warning    |0      |0        |=          |
+-----------+-------+---------+-----------+
|error      |0      |0        |=          |
+-----------+-------+---------+-----------+



Messages
--------

+-----------+------------+
|message id |occurrences |
+===========+============+




-------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 9.64/10, +0.36)

```